Controls and compliance checklist

To complete the controls assessment checklist, refer to the information provided in the scope, goals, and risk assessment report. For more details about each control, including the type and purpose, refer to the control categories document.

Then, select “yes” or “no” to answer the question: *Does Botium Toys currently have this control in place?*

Controls assessment checklist

Yes	No	Control
	X	Least Privilege
	X	Disaster recovery plans
	X	Password policies
	X	Separation of duties
X		Firewall
	X	Intrusion detection system (IDS)
	X	Backups
X		Antivirus software
	X	Manual monitoring, maintenance, and intervention for legacy systems
	X	Encryption
	X	Password management system
X		Locks (offices, storefront, warehouse)
X		Closed-circuit television (CCTV) surveillance

X		Fire detection/prevention (fire alarm, sprinkler system, etc.)

To complete the compliance checklist, refer to the information provided in the scope, goals, and risk assessment report. For more details about each compliance regulation, review the controls, frameworks, and compliance reading.

Then, select "yes" or "no" to answer the question: *Does Botium Toys currently adhere to this compliance best practice?*

Compliance checklist

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best practice
	X	Only authorized users have access to customers' credit card information.
	X	Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment.
	X	Implement data encryption procedures to better secure credit card transaction touchpoints and data.
	X	Adopt secure password management policies.

General Data Protection Regulation (GDPR)

Yes	No	Best practice
	X	E.U. customers' data is kept private/secured.
X		There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach.
	X	Ensure data is properly classified and inventoried.

X		Enforce privacy policies, procedures, and processes to properly document and maintain data.

System and Organizations Controls (SOC type 1, SOC type 2)

Yes	No	Best practice
	X	User access policies are established.
	X	Sensitive data (PII/SPII) is confidential/private.
X		Data integrity ensures the data is consistent, complete, accurate, and has been validated.
X		Data is available to individuals authorized to access it.

This section is *optional* and can be used to provide a summary of recommendations to the IT manager regarding which controls and/or compliance best practices Botium Toys needs to implement, based on the risk posed if not implemented in a timely manner.

Recommendations (optional): In this section, provide recommendations, related to controls and/or compliance needs, that your IT manager could communicate to stakeholders to reduce risks to assets and improve Botium Toys' security posture.

Botium Toys has a risk score of 8 out of 10. The biggest gaps are in access control, data protection and recovery. Closing them lowers the chance of a breach and of fines under PCI DSS and GDPR. I recommend this order:

1. Protect cardholder data and PII (PCI DSS, GDPR, SOC 2). Encrypt credit card data and customer PII, both at rest in the internal database and in transit. Limit access with least privilege and role-based access, so only staff who handle payments can see

cardholder data. Add separation of duties so one person cannot both grant and approve access or change financial records. Write a formal user access policy and review accounts every quarter.

2. Make sure the business can recover. Create a disaster recovery plan and set up regular backups of critical data, including the customer, ecommerce and inventory databases. Keep at least one copy offline or offsite and test a restore at least twice a year. Today a ransomware attack or a disk failure could stop online sales with no way back.

3. Add detection. Install an intrusion detection system (IDS) on the internal network. The firewall and antivirus block known threats, but they do not show suspicious activity that is already inside the network.

4. Fix passwords. Update the password policy to current minimum requirements (at least eight characters, letters, at least one number and special characters). Introduce a centralized password management system that enforces the policy. This also reduces reset tickets to the IT department. Multi-factor authentication for admin and remote accounts is a good next step.

5. Know and classify the assets. Build a full asset inventory and classify data by sensitivity, as the Identify function in the NIST CSF requires. GDPR also expects this. Set a fixed schedule for monitoring and maintaining legacy systems, with clear steps for who intervenes and how, and plan to replace end-of-life systems.

6. Round off physical security. Locks, CCTV and fire detection are already in place. Locking cabinets for network gear, adequate lighting, alarm provider signage and a time-controlled safe would cover the remaining physical controls.

The firewall, antivirus, the 72-hour breach notification plan, the privacy policies and the controls for data integrity and availability work today and should be kept as they are.